

MintStack Finance Portal

Teknik Dokümantasyon, Mimari Analiz ve Production Readiness

Türkiye Odaklı Finans Platformu
Gerçek Zamanlı Piyasa İzleme ve Portföy Yönetimi

Belge Alanı	Değer
Sürüm	2.1
Tarih	05 Temmuz 2026
Hazırlayan	Mesut Taha Güven
Kaynak Durum	Kod HEAD 2d3f6ee + 05 Temmuz 2026 docs/config doğrulaması
Gizlilik	Teknik değerlendirme ve ekip içi kullanım

Bu sürüm, v1.5 ve v2.0 analizlerini tek doğrulanmış teknik referansta birleştirir.

İçindekiler

Bölüm	Başlık
1	Yönetici Özeti ve Güncel Durum
2	Kapsam, Terminoloji ve Başarı Kriterleri
3	Teknoloji Yığını ve Repo Envanteri
4	Sistem Mimarisi ve Veri Akışları
5	Backend Tasarımı
6	Frontend Tasarımı
7	Veri Modeli, Tutarlılık ve Migrasyonlar
8	Güvenlik ve Kimlik Yönetimi
9	Infrastructure, Docker ve Deployment
10	CI/CD, Test ve Kalite Kapıları
11	Performans, Ölçeklenebilirlik ve Gözlemlenebilirlik
12	Riskler, Teknik Borç ve Production Kapıları
13	Operasyon Rehberi
14	Sonuç ve Yol Haritası
A	Ekler: Endpoint, Scheduler, Port ve Doğrulama Matrisi

Okuma Notu

“Doğrulandı” ifadeleri kod, test çıktısı veya çalışan Docker stack üzerinden gözlemlenen durumu; “inference” ifadeleri ise mimari çıkarımı belirtir.

1) Yönetici Özeti ve Güncel Durum

MintStack Finance Portal; piyasa verisi toplama ve izleme, sanal portföy, emir yaşam döngüsü, teknik analiz, simülasyon, haber zenginleştirme ve bildirim yeteneklerini tek Spring Boot backend ve React SPA içinde sunan modüler monolith bir finans platformudur.

Net Karar

Development ortamı kullanılabilir ve uçtan uca çalışır durumdadır. Production dağıtımı için mimari temel yeterlidir; ancak wildcard CORS davranışı, Fintables/webhook güvensiz compose varsayılanları, gerçek TLS materyali, blocking security scan ve restore/failover tatbikatı tamamlanmadan “production-ready” kabul edilmemelidir.

1.1 Doğrulanmış Sistem Durumu

Kontrol	Sonuç	Kanıt / Not
Development Docker stack	PASS	16 servis; kritik container health durumları healthy
Uygulama giriş noktası	PASS	http://localhost:8088 → HTTP 200
Backend health	PASS	/actuator/health → HTTP 200
Keycloak OIDC discovery	PASS	Realm discovery endpoint → HTTP 200
OpenSearch	PASS	Tek node, cluster green; duplicate init container kaldırıldı
Flyway	PASS	V30 ve V31 canlı PostgreSQL üzerinde uygulandı
Backend kalite kapısı	PASS	314 unit/slice + 10 integration; JaCoCo gate geçti
Frontend kalite kapısı	PASS	26 test dosyası, 178 test; lint, typecheck ve build geçti
Prometheus targetları	PASS	backend, Kafka exporter, OTEL ve Prometheus targetları up
Production operasyonu	BLOCKED	CORS + güvenli default + secret/TLS/restore kapıları açık

1.2 Production Readiness Skoru

Alan	Skor	Değerlendirme
Mimari kalite	8.0/10	Modüler monolith doğru; bazı büyük servisler ayrıştırılmalı.
Backend	7.5/10	Katmanlama ve test güçlü; production security profile ayrımı eksik.

Alan	Skor	Değerlendirme
Frontend	7.5/10	RTK Query ve route ayrımı iyi; kapsam ve büyük sayfalar iyileştirilmeli.
Güvenlik	6.0/10	JWT/RBAC güçlü; CORS ve production default blocker'ları kapanmadı.
Test	7.0/10	Kritik testler yeşil; frontend genel coverage yaklaşık %20.
CI/CD	6.5/10	Test/build güçlü; OWASP ve Trivy adımları şu an non-blocking.
Docker/Deploy	6.5/10	Ağ/secret yapısı var; güvenli default ve prod tatbikatı eksik.
Dokümantasyon	8.5/10	Markdown ve teslim belgeleri repo/config ile yeniden eşitlendi.
Genel	7.0/10	Development hazır; production güvenlik kapıları nedeniyle bloklu.

2) Kapsam, Terminoloji ve Başarı Kriterleri

2.1 Kapsam Dahili

- React 18 + TypeScript + Vite SPA; RTK Query tabanlı API katmanı ve WebSocket istemcisi.
- Spring Boot 3.4.2 / Java 21 REST API; controller, service, repository, DTO, mapper ve scheduler katmanları.
- Portföy, pozisyon, işlem geçmişi, MARKET/LIMIT/STOP emirleri ve FIFO lot tüketimi.
- Döviz, hisse, tahvil/bono, fon, VIOP ve endeks verisi; aktif kullanıcı akışında kripto yoktur.
- TCMB, TEFAS, BIST DataStore, Yahoo Finance, Alpha Vantage ve Finnhub adaptörleri.
- Redis cache/rate limit, Kafka event akışı, OpenSearch log/search, OTEL, Prometheus ve Grafana.
- Keycloak OIDC/PKCE, JWT resource server, RBAC, TOTP ve OpenLDAP federation.
- Development/light/production Docker Compose topolojileri ve GitHub Actions kalite hattı.

2.2 Kapsam Harici

- Gerçek para ile aracı kuruma emir iletimi ve saklama hizmeti.
- SPK/MiFID/KVKK uyum süreçlerinin tam otomasyonu ve hukuki sertifikasyon.
- HFT/ultra-low-latency işlem motoru ve çok bölgesel active-active dağıtım.
- Native mobil uygulama ve kullanıcıya yatırım tavsiyesi üretimi.

2.3 Başarı Kriterleri

- CI test, lint, typecheck, build ve migration adımları yeşil olmalıdır.
- Kimlik doğrulama issuer + audience/authorized-party kontrolleriyle uygulanmalıdır.
- Finansal veri değişiklikleri transaction ve veritabanı constraint'leriyle korunmalıdır.
- Liste endpoint'leri pagination ve toplu sorgularla N+1 üretmemelidir.
- Health, metrik, log ve trace akışları uygulama dışından gözlemlenebilmelidir.
- Production secret'ları repoda veya container healthcheck metadata'sında bulunmamalıdır.

2.4 Temel Terminoloji

Terim	Açıklama
Modüler monolith	Tek deployable backend içinde domain odaklı servis sınırları.
OIDC / PKCE	Keycloak tabanlı kimlik doğrulama ve SPA authorization code güvenliği.
RBAC	USER ve ADMIN rollerine dayalı endpoint yetkilendirmesi.
KRaft	Zookeeper olmadan çalışan Kafka metadata yönetimi.
DLT	İşlenemeyen Kafka mesajlarının dead-letter topic'e taşınması.
ShedLock	Çok replica scheduler çalışmasında tekil görev kilidi.
Backfill	Geçmiş fiyat verisinin idempotent biçimde price_history'ye yüklenmesi.
Production gate	Canlıya çıkışı engelleyen zorunlu teknik/operasyonel koşul.

3) Teknoloji Yığını ve Repo Envanteri

3.1 Güncel Teknoloji Matrisi

Katman	Teknoloji	Sürüm / Durum	Kullanım
Backend	Java / Spring Boot	21 / 3.4.2	REST, güvenlik, scheduler, veri erişimi
Güvenlik	Spring Security / Keycloak	6.4.x / 26.5.4	JWT, OIDC, RBAC, PKCE, TOTP
Veri	PostgreSQL / Flyway	15 / 10.20.1	ACID veri ve 31 migration
Cache	Redis / Bucket4j	7 / 8.7.0	Cache ve dağıtık rate limiting
Event	Kafka KRaft	Confluent 7.5.0	Market data, notification ve log event'leri
Search	OpenSearch / client	2.13.0 / 2.13.0	Log ve arama indeksleri
Frontend	React / TypeScript / Vite	18.x / 5.9 / 7.3.6	SPA ve optimize build
State	Redux Toolkit / RTK Query	2.11.2 (lock)	Global state ve API cache
Test	JUnit/Mockito/JaCoCo	5 / - / 0.8.11	Backend kalite kapısı

Katman	Teknoloji	Sürüm / Durum	Kullanım
Test	Vitest/Playwright	4.1.9 / 1.57 (lock)	Frontend unit ve E2E
Observability	OTEL/Prometheus/Grafana	0.91 / 2.48 / 10.2	Trace, metrik ve dashboard

3.2 Repo Envanteri

Varlık	Adet	Not
Backend controller	20	REST ve observability endpoint'leri
Backend service sınıfı	67	Alt paketler dahil; ayrıştırma devam etmeli
JPA entity	19	UUID + optimistic locking kullanılan modeller
Repository	17	JPA ve native batch sorguları
Flyway migration	31	Son migration finansal constraint ve indeksleri içerir
Backend test sınıfı	53	Unit, slice ve integration
Frontend test dosyası	26	178 test
Frontend sayfa / bileşen	22 / 54	pages ve components dizinleri
Development Compose servisi	16	Tek OpenSearch node + ayrı Dashboards

Sürüm Tutarlılığı

Önceki v2.0 belgede geçen 29 migration, %50/%35 JaCoCo eşiği ve 25 frontend test dosyası güncel değildi. Gerçek Maven gate %35 satır / %12 branch; frontend coverage baseline yaklaşık %19–20'dir.

4) Sistem Mimarisi ve Veri Akışları

4.1 Mimari Yaklaşım

Sistem için modüler monolith yaklaşımı doğru seçimdir. Domain hacmi ve ekip ölçeği bağımsız mikroservis operasyon yükünü henüz gerekçelendirmemektedir. Kafka, Redis ve OpenSearch altyapısı belirli ihtiyaçları karşılar; bunlar backend domainlerini ayrı deployable servislere dönüştürmez.

Katman	Bileşenler	Sorumluluk
Edge	Nginx	Tek giriş noktası, reverse proxy, TLS, güvenlik header'ları

Katman	Bileşenler	Sorumluluk
UI	React SPA	Kullanıcı akışları, client-side state, WebSocket abonelikleri
Identity	Keycloak + LDAP	OIDC, kullanıcı/rol, TOTP ve federation
Application	Spring Boot	REST, domain kuralları, transaction, scheduler
Data	PostgreSQL + Redis	Kalıcı doğruluk kaynağı ve sıcak veri cache
Event/Search	Kafka + Logstash + OpenSearch	Asenkron event, DLT, log ve arama
Observability	OTEL + Prometheus + Grafana	Trace, metrik, alarm ve dashboard

4.2 Ana İstek Akışı

1. Tarayıcı, Nginx üzerinden SPA veya /api/v1 endpoint'ine erişir.
2. SPA, Keycloak authorization code + PKCE akışıyla access token alır.
3. Backend JWT imzası, issuer ve audience/authorized-party bilgisini doğrular.
4. Controller yalnızca HTTP sözleşmesini yönetir; iş kuralı service katmanında çalışır.
5. Transaction içinde PostgreSQL güncellenir; ilgili cache invalidation uygulanır.
6. Gerekirse Kafka event'i ve Redis tabanlı WebSocket fanout yayını üretilir.
7. Log/trace/metrik verileri gözlemlenebilirlik hattına aktarılır.

4.3 Piyasa Verisi Akışı

Adım	Akış	Kontrol
1	ShedLock korumalı scheduler tetiklenir	Replica'lar arasında tekil çalıştırma
2	Provider adapter dış API'den veriyi çeker	Timeout, fallback ve normalizasyon
3	Instrument/price_history kaydı yapılır	Idempotency ve transaction
4	Redis cache güncellenir	TTL ve invalidation
5	Kafka market-data event'i üretilir	Retry + DLT
6	Cluster WebSocket publisher Redis pub/sub ile fanout yapar	Çok backend replica desteği
7	Frontend RTK cache/UI güncellenir	Loading/error/reconnect yönetimi

4.4 Portföy ve Emir Akışı

- MARKET emirleri geçerli piyasa fiyatında; LIMIT/STOP emirleri koşul oluştuğunda işlenir.
- BUY işlemleri bakiye, SELL işlemleri pozisyon miktarı doğrulamasından geçer.
- FIFO lot tüketimi, filledQuantity ve averageFillPrice tutarlılığı korunur.
- Portfolio transaction geçmişisi cascade delete ile kaybedilmez; silme işlemi geçmiş varsa engellenir.
- Finansal invariants V31 CHECK constraint'leriyle veritabanı sınırında da uygulanır.

5) Backend Tasarımı

5.1 Katmanlama

Katman	Durum	Değerlendirme
Controller	İyi	Versiyonlu endpoint ve DTO tabanlı sözleşme; admin Page serialization DTO moduna alındı.
Service	Orta/İyi	İş kuralları doğru katmanda; bazı büyük sınıflar domain servislere bölünmeli.
Repository	İyi	JPA + kontrollü native batch sorgular; liste ekranlarında N+1 azaltıldı.
Entity	İyi	UUID, optimistic locking ve ilişki constraint'leri mevcut.
DTO/Mapper	İyi	API/entity ayrımı var; kullanılmayan mapper/annotation/aspect temizlendi.
Exception	İyi	Global handler ve production'da detay sızıntısını kapatan ayarlar mevcut.
Config	İyi	JWT, Kafka, Redis, WebSocket ve profile ayrımı görünür.

5.2 Güvenlik ve İş Kuralı Kontrolleri

- JWT decoder issuer ile birlikte finance-backend audience veya izinli azp kontrolü uygular.
- ActiveUserFilter, pasif kullanıcıları scalar repository sorgusuyla 403 olarak engeller.
- WebSocket CONNECT JWT doğrular; client SEND frame'leri reddedilir ve subscription destination allowlist uygulanır.
- Rate limit proxy IP çözümü yalnızca güvenilen proxy CIDR'larında X-Forwarded-For kullanır.
- Webhook HMAC-SHA256 doğrulaması constant-time karşılaştırma kullanır; internal Alertmanager için CIDR kontrolü desteklenir.
- Kullanıcı API anahtarları AES-256-GCM converter ile uygulama seviyesinde şifrelenir.

5.3 Transaction ve Concurrency

- Portföy/emir işlemleri transaction sınırında yürütülür; optimistic/pessimistic kilitler kullanım senaryosuna göre uygulanır.
- Scheduler görevleri ShedLock ile çok replica ortamında tekilleştirilir.
- Kafka consumer retry/DLT stratejisi işlenemeyen mesajı görünür kılar.
- DB constraint'leri uygulama validation'ının yarış koşullarında aşılmasını önler.

5.4 Backend Teknik Borçları

Öncelik	Alan	Problem	Aksiyon
P1	CI security	OWASP Dependency Check non-blocking	NVD mirror/API key sağla ve gate'i blocking yap
P0	CORS	SecurityConfig wildcard origin + credentials kullanıyor	CorsProperties ile profile-aware exact origin uygula
P0	Prod defaults	Fintables açık, webhook signature kapalı varsayılan	Compose defaultlarını güvenli hale getir
P1	Service boyutu	Market/portfolio/settings servislerinde yüksek sorumluluk	Domain application service'lere ayır
P1	External API	Provider 404/rate-limit log gürültüsü	Symbol eligibility + negatif cache + ölçümlü retry
P2	Webhook	Alertmanager native HMAC imzalayamıyor	Signing proxy veya bearer token kontratı standardize et
P2	Schema test	Docker bulunmadığında Testcontainers test skip	CI'da zorunlu PostgreSQL service migration gate'i koru

6) Frontend Tasarımı

6.1 Mimari

Frontend React 18, TypeScript, Vite, Redux Toolkit ve RTK Query kullanır. Auth singleton'ı ayrı modüle taşınmış, route ağacı AppRoutes içinde ayrılmış ve legacy Axios servisleri kaldırılmıştır. Böylece veri erişimi tek RTK Query katmanında toplanmıştır.

Alan	Durum	Not
Routing	İyi	Lazy-loaded sayfalar ve ProtectedRoute
Auth	İyi	Keycloak module import; global window token objesi yok
Token refresh	İyi	401 refresh çağrısı shared promise ile serialize edilir

Alan	Durum	Not
API state	İyi	RTK Query endpoint/tag invalidation yaklaşımı
Realtime	İyi	STOMP/SockJS reconnect ve topic subscription
Error/loading	Orta	Bazı büyük sayfalarda daha tutarlı empty/error boundary gerekir
Test coverage	Zayıf/Orta	178 test geçiyor; tüm uygulama coverage yaklaşık %20
Bundle	Orta	Ana bundle ~378 KB, chart chunk ~431 KB; route splitting var

6.2 Güvenlik

- Authorization code + PKCE kullanılır; production bypass yalnızca Vite DEV koşuluyla sınırlandırılmıştır.
- DOMPurify ile HTML içeriği sanitize edilir.
- Sentry session replay text/media masking etkinleştirilmiştir.
- Production source map kapalıdır.
- Production Nginx CSP uygular; ancak script/style için unsafe-inline halen açık ve daraltılmalıdır.

6.3 Önerilen Frontend İyileştirmeleri

- AnalysisPage, StocksPage ve CurrencyPage gibi büyük sayfaları view-model hook + presentational component olarak böl.
- Auth, portfolio trade, alert ve settings için gerçek kullanıcı E2E senaryolarını backend ile birlikte çalıştır.
- Coverage eşliğini çeyreklik hedeflerle %20 → %35 → %50 yükselt.
- Charts chunk'ını grafik türü bazında lazy load ederek başlangıç indirmesini düşür.

7) Veri Modeli, Tutarlılık ve Migrasyonlar

7.1 Ana Varlıklar

Domain	Tablolar	İlişki / Not
Identity	users, user_api_configs, user_data_preferences	Keycloak subject ile eşleşme; credential kolonları encrypted TEXT
Portfolio	portfolios, portfolio_items, portfolio_transactions	Sahiplik, pozisyon ve immutable işlem geçmişi
Market	instruments, price_history, currency_rates	Instrument merkezli fiyat zaman serisi
Watch/Alert	watchlists, watchlist_items, price_alerts	Kullanıcıya bağlı izleme ve tetikleme
Content	news, news_categories	Kaynak/hash ile deduplication

Domain	Tablolar	İlişki / Not
Notification	user_notifications	Kafka + WebSocket teslimi
Operations	backfill_jobs, simulation_configs	Uzun iş ve simülasyon durumu

7.2 V30 ve V31 Değişiklikleri

- V30, portfolio_items audit/unique düzeltmesini doğru migration sırasına taşır.
- V31, user_api_configs credential kolonlarını TEXT yapar ve AES-GCM ciphertext saklamaya hazırlar.
- Portfolio transaction FK ON DELETE RESTRICT olarak değiştirilir.
- Bakiye, miktar, fiyat ve fill consistency için CHECK constraint'leri eklenir.
- Currency/news/portfolio transaction/price alert sorguları için bileşik ve partial indeksler eklenir.
- Instrument/news/user araması için pg_trgm GIN indeksleri eklenir.

7.3 Performans Sorguları

- Recent history, tarih öncesi en yakın kayıt ve 52 haftalık aralık toplu repository sorgularıyla hesaplanır.
- Admin portfolio count sorgusu projection ile batch çalışır.
- Liste endpoint'lerinde per-instrument harici volume çağrısı kaldırılmıştır.
- Pagination zorunlu olmayan büyük veri endpoint'leri için üst sınır ve cursor yaklaşımı ayrıca değerlendirilmeli.

Veri Güvenliği

V31'in mevcut production verisine uygulanması öncesinde constraint'leri ihlal eden legacy kayıtlar dry-run SQL ile kontrol edilmeli; migration backup ve rollback prosedürüyle birlikte çalıştırılmalıdır.

8) Güvenlik ve Kimlik Yönetimi

8.1 Auth Akışı

1. SPA, Keycloak realm'e PKCE code challenge ile yönlendirilir.
2. Kullanıcı parola ve gerekiyorsa TOTP ile doğrulanır.
3. Frontend access token'ı memory içinde kullanır ve RTK base query'ye ekler.
4. Backend JWKS imzası, issuer ve audience/azp doğrular.
5. Role converter USER/ADMIN yetkilerini Spring Security authority'lerine map eder.
6. ActiveUserFilter veritabanındaki kullanıcı durumunu doğrular.

8.2 Güvenlik Kontrol Matrisi

Kontrol	Durum	Kanıt / Eksik
JWT signature + issuer	Uygulandı	NimbusJwtDecoder + issuer validator
Audience / azp	Uygulandı	finance-backend audience veya izinli frontend azp

Kontrol	Durum	Kanıt / Eksik
RBAC	Uygulandı	USER/ADMIN endpoint kuralları
TOTP	Uygulandı	Keycloak required action; production policy ayrıca yönetilmeli
CORS	BLOCKER	SecurityConfig APP_CORS_* yerine wildcard + credentials kullanıyor
CSRF	Uygun	Stateless bearer API; browser cookie auth kullanılmıyor
Rate limiting	Uygulandı	Redis Bucket4j, prod fail-closed
WebSocket auth	Uygulandı	CONNECT JWT + destination allowlist
API key at-rest encryption	Uygulandı	AES-256-GCM; APP_FIELD_ENCRYPTION_KEY secret
Webhook	Kısmi	HMAC mevcut; production compose varsayılanı signature=false
Provider policy	BLOCKER	Production compose Fintables varsayılanı true
Secret management	Kısmi	Prod Docker secrets var; rotation/history kanıtı operasyonel
Container vulnerability gate	Eksik	Trivy adımı non-blocking
TLS	Kısmi	Nginx/LDAP/OpenSearch CA materyali deployment sırasında sağlanmalı

8.3 Production Güvenlik Kapıları

- Kafka, OpenSearch, Keycloak, PostgreSQL, Redis, Grafana, LDAP ve uygulama encryption anahtarlarını rotate et.
- Geçmişte izlenen credential dosyalarını Git history'den purge et ve rotasyon sonrasında eski değerleri revoke et.
- SecurityConfig'i CorsProperties ile profile-aware yap; production'da yalnız PUBLIC_APP_ORIGIN kabul et.
- Production compose'da Fintables defaultunu false, webhook signature defaultunu true yap.
- Nginx/LDAP/OpenSearch için doğrulanabilir CA zinciri ve hostname doğrulaması kullan; insecure_skip_verify kapat.
- OWASP ve Trivy security adımlarını blocking yap; kabul edilen CVE'ler için süreli waiver kaydı tut.
- Keycloak production realm'de demo kullanıcı, localhost redirect ve direct access grant bulundurma.

9) Infrastructure, Docker ve Deployment

9.1 Development Topolojisi

Servis Grubu	Servisler	Durum
Application	nginx, frontend, backend	Healthy
Identity	keycloak, openldap	Keycloak healthy; LDAP running
Data	postgres, redis	Healthy
Messaging/Search	kafka, kafka-exporter, opensearch, dashboards, logstash	Kafka/OpenSearch healthy
Observability	otel-collector, prometheus, grafana, alertmanager	Critical health checks healthy

9.2 Production Compose Özellikleri

- data/app/auth/obs ağ segmentasyonu ve minimum port exposure.
- Docker secret file desteği ve backend endpoint üzerinden *_FILE çözümü.
- Keycloak optimized custom image, management health portu ve reverse proxy /auth path.
- Backend replica desteği, ShedLock scheduler tekilleştirme ve Redis WebSocket fanout.
- Healthcheck, restart policy, volume ve kaynak limitleri.
- OpenSearch tek-node deployment için cluster.default_number_of_replicas=0; Dashboards ayrı UI servisi.
- Bilinen blocker: CORS property'leri security chain'de kullanılmıyor; Fintables/webhook defaultları güvenli değil.

9.3 Deployment Öncesi Zorunlu Değişkenler

Kategori	Değişken / Secret	Kural
Public URL	PUBLIC_APP_ORIGIN, VITE_KEYCLOAK_URL, VITE_WS_URL	Exact HTTPS origin; CORS fix sonrası etkili
Database	postgres_password	Random, unique, rotated
Identity	keycloak_admin_password, backend client secret	Demo değeri yok
Cache/Event	redis_password, KAFKA_SASL_PASSWORD	Secret file / orchestrator secret
Search	OPENSEARCH_INITIAL_ADMIN_PASSWORD + CA	TLS verify açık
Application	app_field_encryption_key	32-byte AES key; backup prosedürü
External APIs	provider API keys	Least privilege ve quota alarmı

Production Dağıtım Kararı

docker-compose.prod.yml statik olarak doğrulanabilir; fakat gerçek production hazır kabulü için staging üzerinde TLS, secret mount, migration, rolling restart, backup/restore ve alarm teslimi birlikte kanıtlanmalıdır.

10) CI/CD, Test ve Kalite Kapıları

10.1 Doğrulanmış Test Sonuçları

Katman	Sonuç	Ölçüm
Backend unit/slice	PASS	314 test
Backend integration	PASS	10 test; 1 schema Testcontainers testi yerel provider nedeniyle skip olabildi
JaCoCo	PASS	Maven gate: %35 line / %12 branch
Frontend unit	PASS	26 dosya / 178 test
Frontend coverage	PASS baseline	Statements %19.47, branches %14.57, functions %14.50, lines %19.93
Frontend lint/typecheck/build	PASS	Vite 7.3.6 production build
Docker smoke	PASS	16 servis + HTTP/OIDC/market API doğrulaması
Flyway live validation	PASS	V30/V31 PostgreSQL üzerinde success

10.2 GitHub Actions Hattı

- Gitleaks full history taraması.
- Backend clean verify ve JaCoCo raporu.
- OWASP Dependency Check raporu ve cache.
- Flyway migrate + validate.
- Frontend lint, typecheck, Vitest coverage ve production build.
- Playwright Chromium E2E.
- Backend/frontend image build ve Trivy taraması.
- Development/light/production Compose config doğrulaması.

Kritik CI Notu

Mevcut workflow'da OWASP Dependency Check ile iki Trivy adımı continue-on-error çalışır. Bu nedenle CI'nin yeşil olması tek başına "kritik CVE yok" anlamına gelmez. Production branch protection öncesinde bu adımlar blocking hale getirilmelidir.

10.3 Test Öncelik Planı

Öncelik	Test	Amaç
P0	Auth + audience + inactive user integration	Yetkisiz erişimi engelle
P0	Portfolio concurrent trade + DB constraint	Çifte harcama/negatif bakiye önle
P1	Flyway clean PostgreSQL schema validation	Entity-migration drift yakala
P1	Kafka retry/DLT + notification delivery	Mesaj kaybını görünür yap
P1	Keycloak browser PKCE/TOTP E2E	Gerçek login akışını doğrula
P2	Frontend critical user journeys	Coverage'i risk odaklı artır
P2	Load test	P95 latency, pool ve scheduler davranışını ölç
P2	Backup/restore drill	RPO/RTO kanıtı üret

11) Performans, Ölçeklenebilirlik ve Gözlemlenebilirlik

11.1 Performans İyileştirmeleri

- Instrument listeleri batch price history ve 52-week aggregation sorguları kullanır.
- Admin portfolio count ve tarih aralığı hesapları N+1 yerine batch sorgulara taşınmıştır.
- Redis cache ve explicit invalidation sıcak veri erişimini azaltır.
- Frontend route splitting ve manual vendor/chart chunks kullanır.
- Scheduler aralıkları veri türünün değişim hızına göre ayrıştırılmıştır.

11.2 Ölçeklenebilirlik

Bileşen	Yatay Ölçek	Sınırlama / Aksiyon
Backend REST	Uygun	Stateless JWT; shared PostgreSQL/Redis/Kafka
WebSocket	Uygun	Redis pub/sub cluster fanout; sticky session ihtiyacı test edilmeli
Scheduler	Uygun	ShedLock; lock TTL/iş süresi alarmlanmalı
PostgreSQL	Dikey + read replica	Connection pool ve time-series büyümesi izlenmeli
Kafka	Kısmi	Tek broker dev/prod compose HA değildir

Bileşen	Yatay Ölçek	Sınırlama / Aksiyon
OpenSearch	Kısmi	Tek node compose HA değildir; gerçek prod çok-node planı gerektirir
Frontend	Uygun	Statik asset CDN/cache ile ölçeklenebilir

11.3 Gözlemlenebilirlik

- Spring Actuator metrikleri Prometheus tarafından scrape edilir.
- Kafka exporter consumer lag görünürlüğü sağlar.
- OTEL Collector trace/metric/log pipeline'lerini işler; memory limiter ve batch ayarları kaynak limitine hizalanmıştır.
- Grafana dashboard provisioning ve Alertmanager webhook akışı bulunur.
- Log correlation için traceld/spanld structured log alanları korunmalıdır.

11.4 Ölçülmesi Gereken SLO'lar

SLO	Başlangıç Hedefi	Ölçüm
API availability	$\geq \%99.5$ / ay	Prometheus probe + ingress 5xx
Read API latency	P95 < 500 ms	http.server.requests
Trade command latency	P95 < 800 ms	Custom timer + DB spans
Kafka consumer lag	< 1.000 mesaj	kafka_exporter
Scheduler success	$\geq \%99$	Job success/failure counter
RPO / RTO	≤ 15 dk / ≤ 60 dk	Backup restore tatbikatı

12) Riskler, Teknik Borç ve Production Kapıları

Öncelik	Alan	Problem	Risk	Öneri	Efor
P0	Security	SecurityConfig wildcard CORS + credentials	Cross-origin policy production env'i yok sayıyor	CorsProperties ile profile-aware exact origin	Orta
P0	Config	Fintables=true ve webhook signature=false prod defaultları	Doğrulanmamış provider ve imzasız internal çağrı	Güvenli compose defaultları + test	Düşük
P0	Security	Git history'de geçmiş credential izi riski	Credential replay ve yetkisiz erişim	History purge + tüm ilgili secret'ları rotate/revoke	Yüksek

Öncelik	Alan	Problem	Risk	Öneri	Efor
P0	Deployment	Production TLS/CA ve secret dosyaları ortam dışı	Startup veya MITM riski	Staging’de gerçek secret/TLS mount smoke testi	Orta
P1	CI/CD	OWASP/Trivy non-blocking	Yeşil CI kritik CVE içerebilir	API key/mirror sağla, gate’i blocking yap	Düşük
P1	Keycloak	Prod realm/demo redirect ayrımı operasyonla doğrulanmalı	Auth bypass veya redirect riski	Prod-only realm export + browser E2E	Orta
P1	Data	Restore tatbikatı kanıtı yok	RPO/RTO bilinmiyor	Otomatik backup + düzenli restore drill	Orta
P1	Search/Event	Compose tek Kafka/OpenSearch node	Tek hata noktası	Managed/çok-node prod topolojisi	Yüksek
P2	Frontend	Genel coverage yaklaşık %20	UI regresyonu	Risk bazlı test + kademeli threshold	Orta
P2	Backend	67 service sınıfı ve bazı büyük servisler	Bakım maliyeti	Domain/application service refactor	Yüksek
P2	Performance	Otomatik load test yok	Kapasite belirsiz	k6/Gatling CI performance profile	Orta
P3	Repo hygiene	Üretilmiş rapor/artifact geçmişi	Repo büyümesi	Artifact retention ve .gitignore standardı	Düşük

12.1 Go-Live Checklist

Kapı	Zorunlu Kanıt	Durum
Credential	Rotation tarihi + revoke kaydı + history scan	Açık
CORS	Production exact origin integration testi	Açık / Blocker
Safe defaults	Fintables kapalı + webhook imzası zorunlu	Açık / Blocker
TLS	Public/LDAP/OpenSearch certificate verification	Açık
CI security	Blocking OWASP/Trivy ve sıfır kritik CVE	Açık

Kapı	Zorunlu Kanıt	Durum
Migration	Staging snapshot üzerinde V30/V31 migrate/validate	Kısmi
Backup	Başarılı restore ve ölçülmüş RPO/RTO	Açık
Auth	PKCE + TOTP + RBAC browser E2E	Kısmi
Observability	Test alarminın gerçek alıcıya teslimi	Kısmi
Rollback	Önceki image + DB uyumluluk prosedürü	Açık
Performance	Steady-state load test ve capacity raporu	Açık

13) Operasyon Rehberi

13.1 Development Başlatma

Önkoşul: Docker Desktop çalışır durumda ve kök dizinde geçerli `.env` bulunmalıdır.

İşlem	Komut
Compose doğrulama	docker compose config --quiet
Tam stack	docker compose up -d --build
Durum	docker compose ps
Backend log	docker compose logs -f backend
Kapatma	docker compose down
Light stack	docker compose -f docker-compose.light.yml up -d

13.2 Health ve Smoke Kontrolleri

Kontrol	Adres / Komut	Beklenen
UI	http://localhost:8088	HTTP 200
Backend	http://localhost:8088/actuator/health	UP / HTTP 200
Keycloak	http://localhost:8180/realms/mintstack-finance/.well-known/openid-configuration	HTTP 200

Kontrol	Adres / Komut	Beklenen
Grafana	http://localhost:13030/api/health	HTTP 200
OpenSearch Dashboards	http://localhost:15601/app/home	HTTP 200
Prometheus targets	http://localhost:9090/targets	Critical targets UP
Flyway	flyway_schema_history son kayıtları	V30/V31 success=true

13.3 Arıza Ayırma Sırası

1. docker compose ps ile dependency health durumunu kontrol et.
2. PostgreSQL, Redis, Kafka ve Keycloak loglarını backend'den önce incele.
3. Backend startup'ta Flyway/JPA validation ve issuer/JWK erişimini kontrol et.
4. Nginx upstream ve frontend health endpoint'ini doğrula.
5. Prometheus targets, OTEL collector ve OpenSearch cluster health kontrolü yap.
6. Dış API hatasını platform altyapı hatasından ayrı sınıflandır.

13.4 Secret Güvenliği

- Secret değerlerini ticket, log, ekran görüntüsü veya dokümana kopyalama.
- Değer yerine secret adı ve vault/path referansı kullan.
- Şüpheli sızıntıda önce revoke/rotate, sonra history cleanup yap.
- Container inspect içinde genişletilmiş secret barındıran healthcheck/command kullanma.

14) Sonuç ve Yol Haritası

MintStack, eğitim/prototip seviyesini aşan ve kurumsal bileşenleri gerçek entegrasyonlarla kullanan güçlü bir modüler monolith uygulamasıdır. Kod tabanlı development ortamında uçtan uca doğrulanmıştır. En doğru sonraki yatırım yeni özellik eklemek değil; production güvenlik kapılarını kapatmak, restore/load test kanıtı üretmek ve yüksek sorumluluklu servisleri sadeleştirmektir.

14.1 Aşamalı Plan

Faz	Süre	Çıktı
Faz 1	1–2 gün	Credential rotation/history purge, blocking CI scans, prod realm ve TLS doğrulaması
Faz 2	İlk hafta	Backup/restore drill, auth E2E, alarm teslim testi, staging migration kanıtı
Faz 3	Production öncesi	Load test, rollback provası, SLO dashboard ve on-call runbook

Faz	Süre	Çıktı
Faz 4	Uzun vade	Service refactor, coverage artışı, managed Kafka/OpenSearch veya HA topolojisi

Final Değerlendirme

Development readiness: 10/10. Production readiness: 7.0/10. Go-live kararı yalnızca 12.1'deki P0/P1 kapıları kapatıldıktan sonra verilmelidir.

Ek A — Port ve Servis Matrisi

Servis	Development erişimi	Production yaklaşımı
Nginx	8088	80/443 public
Frontend	3002	Yalnız app network
Backend	Internal 8080	Yalnız app network
Keycloak	8180	Nginx /auth
PostgreSQL	127.0.0.1:5432	Yalnız data network
Redis	127.0.0.1:16379	Yalnız data network
Kafka	29092	Yalnız data/obs network
OpenSearch	127.0.0.1:19200	Yalnız data/obs network
Dashboards	15601	Kısıtlı yönetim erişimi
Prometheus	127.0.0.1:9090	Yalnız obs network/VPN
Grafana	13030	SSO/VPN arkasında
Alertmanager	127.0.0.1:9093	Yalnız obs network
OTEL	24317/24318	Yalnız app/obs network

Ek B — Scheduler Frekansları

Görev	Varsayılan cron	Not
BIST hisse	* /20 * * * * *	ShedLock min 5 saniye
VIOP	* /30 * * * * *	ShedLock min 5 saniye

Görev	Varsayılan cron	Not
Tahvil	0 */2 * * * *	Daha düşük değişim hızı
Fon	0 */3 * * * *	Provider quota dengesi
Döviz	0 */5 * * * MON-FRI	TCMB dışı akış
TCMB	0 30 10,16 * * MON-FRI	Resmi yayın ritmi
Haber	0 */15 * * * *	RSS + opsiyonel LLM
Cleanup	0 0 2 * * *	Retention politikasına bağlı